

Núcleo de Pesquisa: Governança de Inteligência Artificial Aplicada ao Desenvolvimento de Software

Esta pesquisa acadêmica e normativa consolida o panorama regulatório e os frameworks de Governança de IA, traduzindo princípios abstratos em diretrizes metodológicas práticas para a Engenharia de Software Assistida por IA.

A. Delimitação

A Governança de Inteligência Artificial, no escopo da Engenharia de Software, delimita-se pela intersecção entre a conformidade normativa (leis e regulamentos) e as boas práticas de gestão de risco em TI (normas técnicas e frameworks). O estudo foca em como princípios abstratos como 'transparência', 'responsabilidade' (accountability) e 'supervisão humana' são traduzidos em controles de acesso, auditoria de prompts e rastreabilidade de código quando ferramentas de IA Generativa são introduzidas no Ciclo de Vida de Desenvolvimento de Software (SDLC).

B. Perguntas de Pesquisa

1. Como as normativas internacionais e a legislação brasileira estabelecem as obrigações de responsabilidade, prestação de contas e gestão de riscos na utilização de modelos de IA?
2. Como as normas técnicas (ex: ISO/IEC 42001) e frameworks (ex: NIST AI RMF) traduzem exigências legais em requisitos de auditoria e documentação aplicáveis ao desenvolvimento de software?
3. Como princípios de governança institucionais podem ser transformados em regras concretas para uma metodologia experimental de Engenharia de Software Assistida por IA (TG)?

C. Subtemas Investigados

- Conceitos Normativos: Lei (obrigação estatal) vs. Norma Técnica (padrão de mercado certificável) vs. Framework (estrutura metodológica voluntária).
- Governança de Modelos e Dados: Controle de acesso, registro de utilização (logging),

transparência algorítmica e proteção de propriedade intelectual/dados sensíveis.

- Gestão de Riscos e Ciclo de Vida: Avaliação de impacto, rastreabilidade, auditoria contínua e mitigação de vieses ou falhas de segurança.
- Fatores Humanos: Supervisão humana (Art. 14 do AI Act), tomada de decisão e limites da automação.

D. Estratégia e Critérios de Seleção

A pesquisa priorizou fontes primárias normativas vigentes até 2026. Consultou-se a legislação europeia consolidada (EU AI Act) por seu efeito extraterritorial e o arcabouço brasileiro (LGPD e o debate legislativo do PL 2338/2023). Para a operacionalização técnica, utilizou-se a norma ISO/IEC 42001:2023 (Sistema de Gestão de IA) e o Framework do NIST (AI RMF 1.0). A literatura acadêmica foi empregada apenas para discutir a implementação destes instrumentos no contexto prático do desenvolvimento de código.

E. Fontes e F. Evidências Extraídas

Fonte 1: ISO/IEC 42001:2023

Natureza: Norma Técnica Internacional.

Autoridade: ISO/IEC (International Organization for Standardization / International Electrotechnical Commission).

Ano: 2023.

Escopo: Sistema de Gestão de Inteligência Artificial (AIMS).

Obrigatoriedade: Voluntária (certificável).

Evidências: A Seção 8 (Operação) exige que as organizações realizem avaliações de risco de IA (8.2) e implementem tratamentos de risco documentados. Relevância para SDLC: Obriga a equipe de engenharia a documentar quais bibliotecas ou prompts gerados por IA apresentam risco de segurança e a estabelecer políticas internas que exijam aprovação humana para deploy de artefatos gerados.

Fonte 2: NIST AI RMF 1.0 (Artificial Intelligence Risk Management Framework)

Natureza: Framework de Governança.

Autoridade: NIST (National Institute of Standards and Technology - Governo dos EUA).

Ano: 2023.

Escopo: Gestão de riscos de sistemas de IA corporativos.

Obrigatoriedade: Voluntária (altamente recomendada como padrão industrial).

Evidências: Baseia-se nas funções Govern, Map, Measure e Manage. A função 'Govern' (GV 1.2 e GV 2.1) estipula que a responsabilidade pelos resultados da IA deve ser claramente mapeada para atores humanos. Relevância para SDLC: Implica que, se a IA gera um código inseguro, a responsabilidade deve ser atribuída metodologicamente ao revisor humano que fez o 'merge' do código, exigindo registros de auditoria rigorosos.

Fonte 3: Regulamento (UE) 2024/1689 (EU AI Act)

Natureza: Legislação (Regulamento Transnacional).

Autoridade: Parlamento Europeu e Conselho da União Europeia.

Ano: 2024.

Escopo: Regulamentação da IA com base em risco no mercado europeu (com efeito extraterritorial em cadeias de software).

Obrigatoriedade: Obrigatória (Lei).

Evidências: O Artigo 14 exige explicitamente a 'Supervisão Humana' (Human Oversight) para prevenir ou minimizar riscos de saúde, segurança ou direitos fundamentais. O Artigo 13 exige 'Transparência'. Relevância para SDLC: Ferramentas corporativas de IA não podem operar como caixas pretas na engenharia; deve haver transparência sobre quais porções de um software comercial foram sintetizadas por modelos probabilísticos.

Fonte 4: Projeto de Lei nº 2338/2023 (Marco Legal da Inteligência Artificial)

Natureza: Projeto de Lei (Legislação em tramitação/consolidação no Brasil).

Autoridade: Senado Federal do Brasil.

Ano: 2023 (com repercussões até 2026).

Escopo: Regulação do uso, desenvolvimento e implementação de IA no Brasil.

Obrigatoriedade: Obrigatória (sujeita a sanção).

Evidências: O Capítulo III garante direitos aos afetados por sistemas de IA, incluindo a explicação sobre decisões automatizadas. O Capítulo IV categoriza riscos. O Art. 36 (na versão original debatida) aborda a responsabilidade civil. Relevância para SDLC: Aliado à LGPD (Lei 13.709/2018), proíbe que dados pessoais reais (como RAs de alunos da FATEC) sejam utilizados em prompts de LLMs públicos para depuração de banco de dados, configurando falha de governança.

G. Análise Crítica

A distinção entre as naturezas documentais é crucial: enquanto o EU AI Act e a legislação brasileira impõem sanções legais em caso de danos (exigindo prestação de contas estrita), elas não explicam **como** aplicar os controles na IDE do desenvolvedor. A literatura acadêmica e os frameworks (como a ISO 42001 e o NIST AI RMF) preenchem essa lacuna. Normas técnicas não são leis, mas servem como escudo de diligência (due diligence): uma empresa autuada legalmente pode usar a certificação ISO/IEC 42001 para provar que adotou padrões razoáveis de segurança e supervisão humana.

H. Composição Acadêmica Única

A integração da Inteligência Artificial Generativa no Ciclo de Vida de Desenvolvimento de Software (SDLC) desafia os modelos tradicionais de responsabilidade e segurança. A Governança de IA emerge como a disciplina estruturante que traduz obrigações legais — como a LGPD no Brasil e o EU AI Act na Europa — em artefatos de engenharia verificáveis. Uma metodologia de desenvolvimento assistido por IA, sem governança, atua em 'shadow IT', expondo o projeto a vazamentos de propriedade intelectual e alucinações algorítmicas indocumentadas.

O núcleo da governança de IA na programação reside na intersecção entre a rastreabilidade e a supervisão humana. De acordo com o Artigo 14 do EU AI Act e as diretrizes do NIST AI RMF, a responsabilidade última (accountability) não pode ser terceirizada para o agente generativo. Isso significa que a organização de desenvolvimento deve implementar políticas internas que documentem onde e como a IA foi utilizada. Na prática, princípios abstratos são convertidos em regras de controle de

acesso (ex: desenvolvedores só podem utilizar LLMs aprovados pela instituição, via API corporativa, para evitar treinamento de modelos públicos com código proprietário) e registro de utilização (logging de prompts).

Sob a ótica da ISO/IEC 42001, a gestão de riscos de IA exige avaliação contínua. Para a Engenharia de Software, isso implica que a delegação de tarefas de codificação para ferramentas automatizadas deve ser mapeada conforme o risco funcional. Módulos críticos, como roteamento de pagamentos ou autenticação de identidades, requerem protocolos de auditoria humana estritos (Code Review obrigatório e atestado manual), enquanto a geração de *boilerplate* pode suportar maior grau de automação. A governança, portanto, atua como o sistema de freios que permite à engenharia acelerar a produtividade com IA, assegurando que o código resultante obedeça às normativas de segurança, proteção de dados e previsibilidade.

I. Implicações para a TG e Tabela de Aplicação

No escopo do Trabalho de Graduação focado na FATEC Barueri, o grupo deve adotar uma "Política Interna de Uso de IA" simplificada, emulando um ambiente de Governança corporativo. É expressamente proibido inserir dados reais de professores e alunos em prompts, adequando-se à LGPD. Além disso, a equipe deve manter um registro documentado de prompts para garantir a rastreabilidade (requisito da ISO 42001).

Instrumento	Princípio / Requisito	Implicação para a TG	Aplicação Possível (Regra)
LGPD (Lei 13.709/18) / PL 2338/23	Privacidade By Design e Proteção de Dados	Impedir vazamento de dados estudantis no LLM	Proibido usar RA, nomes reais ou e-mails em prompts. Usar apenas dados fictícios.
EU AI Act (Art. 14)	Supervisão Humana (Human Oversight)	Garantir que IA não insira código falho no repositório	Obrigatoriedade de Code Review humano manual antes de aceitar PRs gerados por IA.
NIST AI RMF 1.0 (Govern)	Responsabilidade e Prestação de Contas	Atribuir autoria e responsabilidade pelos erros	Quem submete o código revisado da IA assume formalmente a autoria e responsabilidade pela funcionalidade.
ISO/IEC 42001:2023 (Seção 8)	Rastreabilidade e Avaliação de Riscos	Manter histórico auditável do uso da ferramenta	Criação de um repositório "Prompt Library" versionando as

			instruções que geraram a arquitetura.
--	--	--	---------------------------------------

J. Referências ABNT Completas

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 15 ago. 2018.

BRASIL. Senado Federal. Projeto de Lei nº 2338, de 2023. Dispõe sobre o uso da Inteligência Artificial. Brasília, DF: Senado Federal, 2023.

ISO; IEC. ISO/IEC 42001:2023: Information technology — Artificial intelligence — Management system. Genebra: ISO/IEC, 2023.

NIST. Artificial Intelligence Risk Management Framework (AI RMF 1.0). Relatório Técnico. Gaithersburg: National Institute of Standards and Technology, 2023.

UNIÃO EUROPEIA. Regulamento (UE) 2024/1689 do Parlamento Europeu e do Conselho, de 13 de junho de 2024, que estabelece regras harmonizadas em matéria de inteligência artificial (Regulamento da Inteligência Artificial). Jornal Oficial da União Europeia, Bruxelas, 2024.

K. Lacunas de Investigação

- Descompasso temporal: A velocidade com que a GenAI evolui gera um 'débito regulatório', tornando frameworks elaborados em 2023 rapidamente vagos frente a Agentes de Programação totalmente autônomos.
- Há escassez de normas técnicas específicas (em nível ISO) que isolem unicamente a utilização de LLMs dentro de IDEs, sendo o mercado ainda dependente de adaptações de frameworks generalistas de IA.